Enterprise Active Directory & SIEM Threat Hunting Lab

Executive Summary

Engineered a virtualized enterprise Active Directory lab integrated with a Splunk SIEM to simulate and detect real-world adversarial activity. The environment was used to generate telemetry from controlled attacks, map behaviors to the MITRE ATT&CK framework, and develop high-fidelity, threshold-based detection rules. The project demonstrates end-to-end SOC capabilities, including infrastructure deployment, log pipeline engineering, threat simulation, detection engineering, and automated response strategies.

0. Attack Scenario Overview

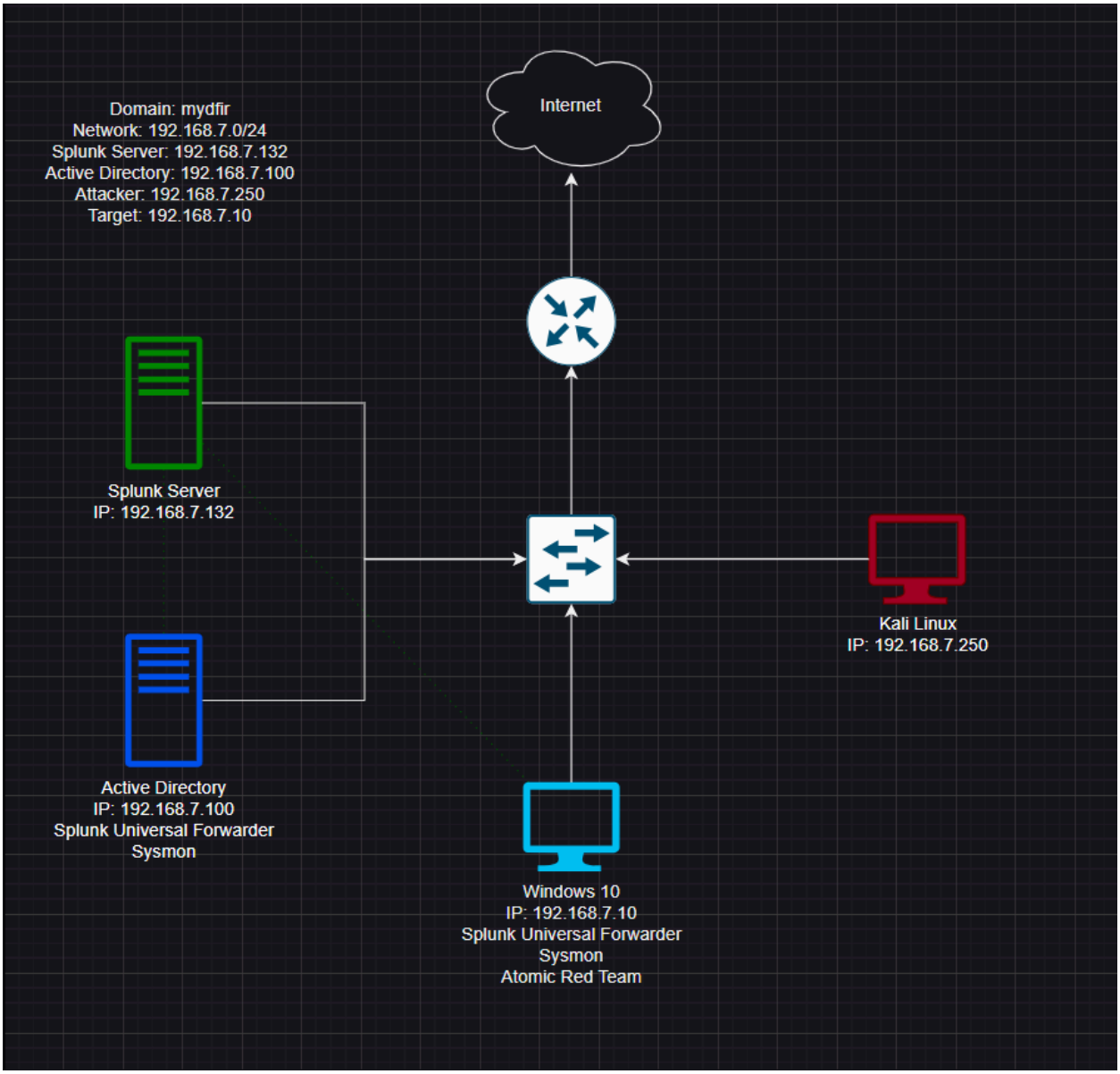
This lab simulates a real-world intrusion scenario in which an external attacker attempts to gain unauthorized access to an enterprise Active Directory environment via RDP brute-force attacks. Upon initial access failure, the attacker escalates tactics by attempting persistence through local account creation using command-line utilities. The SOC pipeline is designed to detect, analyze, and respond to these behaviors in near real-time.

Attack Timeline:

- T+0 min: Attacker initiates RDP brute-force (Hydra)
- T+2 min: Spike in Event ID 4625 detected
- T+2 min: Threshold-based alert triggered in SIEM
- T+5 min: Attacker executes persistence via net user and escalates privileges
- T+5 min: Sysmon logs process creation (Event ID 1)
- T+6 min: Detection of suspicious command-line activity and process lineage correlated

1. Logical Architecture & Network Topology

The environment was built utilizing VMware Workstation, operating within a custom isolated virtual network to safely execute and monitor malware and brute-force simulations.



Infrastructure Specifications:

- Hypervisor: VMware Workstation
- Network Routing: Isolated Virtual Network (VMware NAT / Vmnet7)

- SIEM / Indexer: Ubuntu Server 22.04 LTS (Splunk Enterprise) - 192.168.7.132
- Domain Controller: Windows Server 2022 (ADDS) - 192.168.7.100
- Target Machine: Windows 10 - 192.168.7.10
- Attacker System: Kali Linux - 192.168.7.250

---

2. Data Pipeline Engineering

To ensure high-visibility threat hunting, the environment required a robust log ingestion pipeline. Raw logs lack analytical value without proper parsing, normalization, and enrichment.

Telemetry Generation:

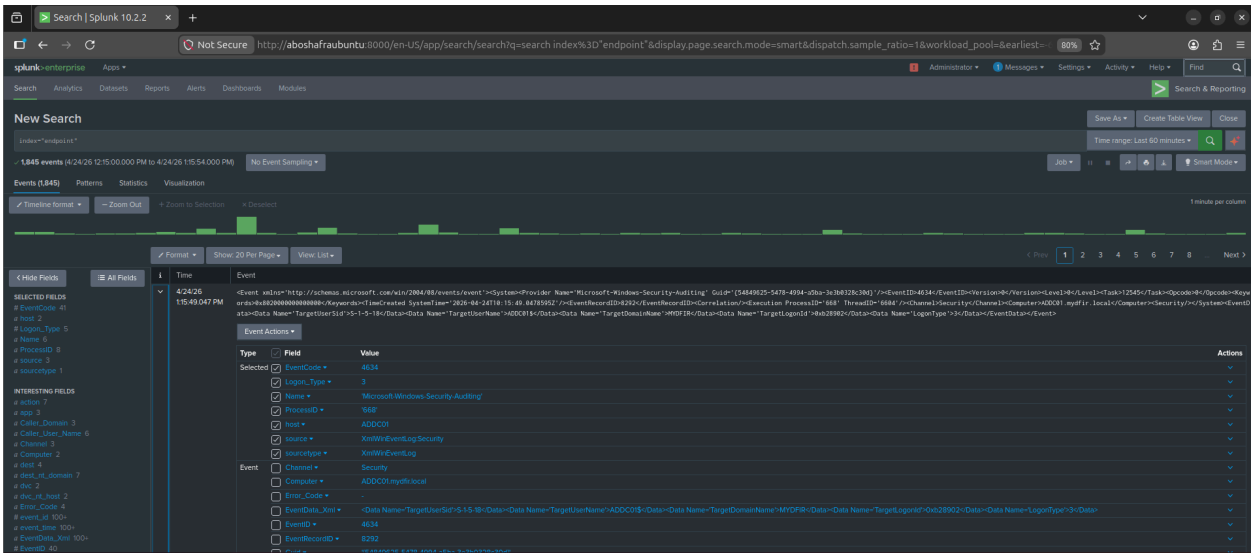
Deployed Sysmon (utilizing Olaf Hartong's configuration) across Windows endpoints to capture granular process creation, network connections, and file modifications.

Log Transport:

Configured the Splunk Universal Forwarder on the Windows Server. Engineered custom inputs.conf files to route Security, Application, System, and Sysmon event logs securely to the SIEM over TCP port 9997 into a dedicated endpoint index.

Data Parsing (CIM Compliance):

Installed the Splunk Add-on for Microsoft Windows on the Search Head. This step was critical to translate raw Microsoft XML event data into Common Information Model (CIM) compliant fields (e.g., dynamically extracting <EventID> into searchable EventCode fields).



---

3. Attack Simulation & Threat Hunting

Adversarial simulations were executed against the domain controller to generate telemetry and validate the detection engineering pipeline.

Tactic: Credential Access (T1110.001 - Password Guessing)

Execution: Conducted a targeted Remote Desktop Protocol (RDP) brute-force attack against the domain account ibrahim using Hydra. By default, aggressive parallel brute-forcing triggers Windows TermService to drop network connections before the Local Security Authority (LSA) can log the attempt. To bypass this Network Level Authentication (NLA) rate-limiting, the attack was optimized to run synchronously.

```
hydra -t 1 -l ibrahim -P password.txt rdp://192.168.7.10
```

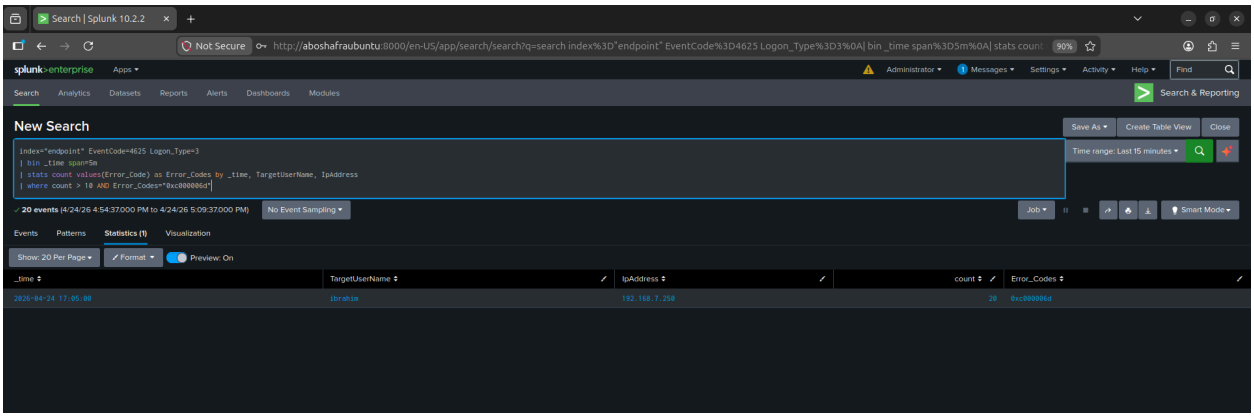
Detection & Analysis:

To avoid base-level alerts that cause alert fatigue, the SIEM was engineered to detect high volumes of authentication failures indicative of an automated attack using time-bounded thresholds.

```
index="endpoint" EventCode=4625 Logon_Type=3
| bin _time span=5m
```

```
| stats count values(Error_Code) as Error_Codes by _time, Tar
getUserName, IpAddress
| where count > 10 AND Error_Codes="0xc000006d"
```

Findings: The custom SPL correlated and validated an anomaly, filtering out isolated authentication errors. It triggered an alert based on a massive spike in Network Logons (Type 3). The query aggregated the 0xc000006d hex value, explicitly confirming "bad authentication information" originating from 192.168.7.250.



Tactic: Persistence & Execution (T1136.001 & T1059.001)

Execution: Deployed the Atomic Red Team framework to automate the simulation of local account creation and PowerShell execution policy bypasses.

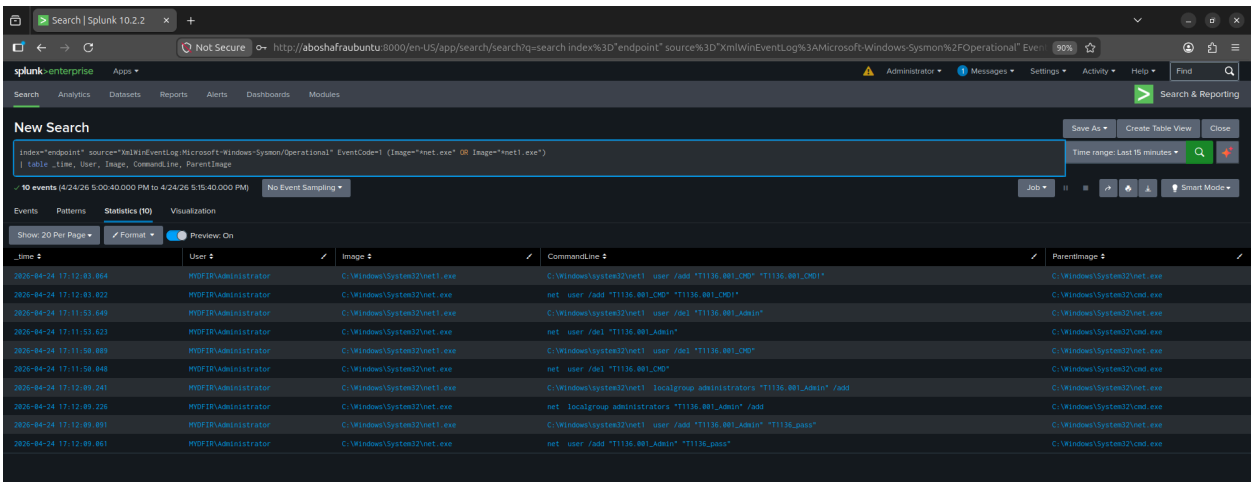
```
Set-ExecutionPolicy-ExecutionPolicyBypass-ScopeCurrentUser
Invoke-AtomicTestT1136.001
```

Detection & Analysis:

While Windows Security Event ID 4720 reliably indicates local account creation, relying solely on it provides incomplete visibility. To build a high-fidelity alert, Sysmon Event ID 1 (Process Creation) was utilized to hunt the underlying execution artifacts and process lineage.

```
index="endpoint" source="XmlWinEventLog:Microsoft-Windows-Sysmon/Operational" EventCode=1
(Image="*net.exe" OR Image="*net1.exe")
| table _time, User, Image, CommandLine, ParentImage
```

Findings: The SIEM successfully extracted the exact command-line arguments used by the framework: net user /add "T1136.001_Admin". Furthermore, the telemetry captured the immediate privilege escalation execution (net localgroup administrators "T1136.001_Admin" /add). By analyzing the process tree, it was confirmed that cmd.exe acted as the ParentImage spawning the net.exe payload wrappers, confirming interactive command-line abuse.



---

4. SOC Detection & Response Workflow

The following workflow details the operational response to the simulated intrusion based on established incident response playbooks.

- **Alert Trigger:**
  - Rule: >10 failed logins within 5 minutes AND specific Error_Code correlation.
    Source: Splunk SIEM
    Severity: High
- **Triage:**
  Analyst validates the spike in EventCode 4625 and confirms repeated,

sustained attempts originating from a single IP address (192.168.7.250).

- **Investigation:**
  Analyst pivots to correlate network logons with Sysmon logs on the target host. Identifies secondary process execution (net.exe) and extracts malicious command-line arguments indicating persistence.
- **Containment:**
  Block source IP (192.168.7.250) at the perimeter firewall / via SOAR platform. Temporarily disable the targeted ibrahim account and the newly created rogue administrator account.
- **Recovery:**
  Reset compromised credentials, remove rogue accounts, and review affected systems for further unauthorized registry or file modifications.

---

5. Recommended Mitigations (Defense Strategy)

A SOC analyst's role is not only to detect but to recommend hardening strategies and automated responses to prevent future occurrences.

Brute Force Mitigation (Credential Access)

- Account Lockout Policy: Implement GPOs to lock accounts for 15 minutes after 5 failed attempts within a 5-minute window. This prevents "low and slow" Hydra attacks.
- MFA Implementation: Enforce Multi-Factor Authentication for RDP sessions via Windows Hello for Business or third-party solutions (Duo/Okta).
- Automated SOAR Containment: Integrate the SIEM with endpoint EDR or edge firewalls to automatically null-route/block source IPs that breach the EventCode 4625 5-minute failure threshold.

Execution & Persistence Mitigation

- GPO Script Restrictions: Configure Group Policy to restrict PowerShell Execution Policy to AllSigned, preventing the execution of unsigned local scripts.

- Application Whitelisting: Utilize AppLocker or Windows Defender Application Control (WDAC) to prevent unauthorized binaries from creating new local user accounts outside of approved administrative workflows.

---

6. Engineering Challenges & Troubleshooting

This section details the technical roadblocks encountered during the build and the investigative methodology used to resolve them.

1. Transparent DNS Interception & Sinkholing

Issue: The Atomic Red Team installation failed because the network dropped outbound DNS queries to raw.githubusercontent.com.

Resolution: Executed a local DNS hijack by hardcoding the authoritative IP address (185.199.108.133) directly into the Windows hosts file (C:\Windows\System32\drivers\etc\hosts), bypassing the network's DNS proxy entirely.

---

2. SIEM Pipeline Time-Drift (NTP Desynchronization)

Issue: Brute-force attacks were not visible within the SIEM's 15-minute search window despite verified ingestion.

Resolution: Identified that the hypervisor sleep state caused the Windows Server to drift into UTC/Zulu time. Resynchronized the local domain clocks to restore chronological search visibility.

---

7. Detection Performance Metrics

- Time to Detect (TTD): ~2 minutes
- Detection Method: Threshold-based SPL correlation & Process Lineage tracking
- False Positives: Minimal (Filtered via Error_Code 0xc000006d + dynamic time window thresholds)
- Data Sources: Windows Security Logs, Sysmon (Operational)

- Detection Coverage: Credential Access (T1110.001), Execution (T1059.001), Persistence (T1136.001)